Guardian Agent Security Self-Assessment

Guardian assumes the LLM, the agent software and the backend can all fail, so its security doesn't rest only on any of them behaving correctly. The critical authority boundaries are enforced independently, by the smart account's delegated permission system.

Limitation, stated up front: the on-chain permission limits asset access, the token-unit transaction size, the call target, the selector, the recipient, the session duration, the operation count and the gas authority. Tests and testnet transactions verify all of these. Live USD valuation, the daily USD budget, risk scoring and market quality (slippage, `amountOutMinimum`) are enforced **off-chain** in this MVP.

Permission-Tier Implementation Matrix

Tier	Signer	When	How it is enforced	Evidence
1. Scoped agent session key	Restricted session key (one per tradable asset)	Every check passes, risk is LOW, size ≤ cap (or a capped `PARTIAL_STEP` for moves up to 3× the cap)	On-chain: CallPolicy (2 selectors, recipient = self, token caps), RateLimitPolicyWithReset, TimestampPolicy, GasPolicy	Tier 1 swap, block 48112653; `gate0-two-way-permissions.json`
2. Master co-sign	Owner wallet (Kernel root)	Valid, but beyond agent authority, or the agent ESCALATEs	Server revalidates with **fresh balances, Chainlink prices and a new QuoterV2 quote** before preparing; the owner signs the exact `userOpHash`	Master-signed sale, block 48113495
3. Deterministic hard gate	None	Policy violation, hard risk gate, HIGH risk, stale oracle, sequencer down	Rejected and audited; never escalated to master automatically	Risk unit tests; audit events
Paper mode	None (simulation only)	Asset has a fresh price feed but no verified USDC pool / quote	Tracked and valued; trades are simulated, never sent	`assets.ts` four-step verification

What the session key can do

Exactly two functions are allowed, both on `SwapRouter02`, and both with the smart account as recipient, the configured pool fee, no price limit and no ETH value:

- **Sell:** exactInputSingle, WETH → USDC, amountIn ≤ the compiled WETH cap (about $10 at the authorization price, with a 15% buffer).
- **Buy:** exactOutputSingle, USDC → WETH, amountInMaximum ≤ the compiled USDC cap ($10 with a 2% buffer). The most a buy can spend is fixed on-chain.

The session lasts 7 days and allows 6 operations per 24 h window (the count resets: RateLimitPolicyWithReset). It requires the approved paymaster and carries a cumulative gas allowance of 0.01 ETH. Router allowances are capped at cap × 42 per token and get cleared on revocation.

Maximum loss if the session key and backend are fully compromised: up to 6 capped swaps a day between WETH and USDC at a poor price, with every output still landing in the owner's account. Nothing can be transferred out or approved to anyone else. Buys can't overspend their cap, even at a bad price. Sells can accept a bad price (risk 1 below). Revocation stops everything immediately.

What the AI can and cannot decide

The agent chooses	Deterministic code / the account decides
REBALANCE, WAIT (1–60 min), ESCALATE or NO_ACTION	Whether the portfolio is out of band at all
A whole-percent target inside the owner's band	The trade size, tokens, pool, recipient, calldata, gas and signature
—	The tier: the agent can only *narrow* it (ESCALATE turns Tier 1 into Tier 2), never widen it

If no provider returns a valid decision, a rule-based rebalance to the owner's target steps in, but only when the trade is Tier 1 and LOW risk. Anything else goes to the master. Three AI failures in a row pause new autonomous actions.

Verified evidence

Claim	Method	Result
Forbidden target, selector, token, fee, recipient, amount, batch, delegatecall	eth_simulateV1 against deployed contracts; each negative differs from a passing positive by one field	All rejected; causes decoded (CallViolatesParamRule, no-permission)
Expiry, operation count (session-wide), gas, paymaster	Same; control cases isolate the gas policy	Rejected with AA22 / PolicyFailed(2) / PolicyFailed(3)
Real bundler rejects forbidden ops signed by the real session key	eth_sendUserOperation to Pimlico, application bypassed	v1: 4/4 rejected. v2 (two-way): 8/8 rejected, including buy-side recipient swap, USDC cap + 1, USDC transfer and USDC approve to an attacker. No transaction hash (evidence/defense-b-bundler-rejections-v2.json)
Two-way permission	eth_simulateV1 against deployed	19/19 cases as expected (evidence/gate0-

Claim	Method	Result
and resetting window	contracts (scripts/gate0/two-way-harness.ts)	two-way-permissions.json)
Revocation	Master uninstall plus grantAccess(false), then the same key retried	A previously allowed swap is rejected; allowance 0
Execution failure is not authorization failure	Permitted swap with impossible minimum output	Outer transaction success; UserOperation success=false ("Too little received")
Autonomous Tier 1 swap	Real WETH transfer trigger	Confirmed, block 48112653
Tier 2 needs the master	Sale of $11.57 > $10	Routed to approval; master-signed, block 48113495
No duplicate execution	8 concurrent claims; parallel budget reservations	Exactly one claim; budget never exceeded

You'll find all the hashes in the Execution Evidence document.

Known-Risk & Mitigation Registry

	Risk	Mitigation in place	Residual / future fix
1	**Sell-side amountOutMinimum unconstrained on-chain.** A compromised backend could execute up to 6 capped sells a day at a bad price.	Off-chain quote-derived minimum; small cap; short session; one-click revocation. Buys are bounded on-chain by amountInMaximum.	Oracle-aware execution guard contract.
2	**Token-unit vs. USD drift.** The WETH cap is worth more dollars if ETH rises.	15% buffer at compile time; re-authorization triggers at a +10% price rise (below the buffer).	Between checks, it depends on the worker staying live.
3	**Testnet pool divergence.** Base Sepolia pools quote about 2× Chainlink.	Testnet threshold relaxed to 200% and every action labeled TESTNET_PRICING; mainnet uses 2%.	None on mainnet.
4	**Unknown submission outcome.**	The account stays locked until the reconciler resolves the operation from chain evidence; no blind retry.	—
5	**Forced on-chain validation failure not**	Bundler-level rejections (real key) and EntryPoint.handleOps simulations prove the same	Needs Sepolia ETH

	Risk	Mitigation in place	Residual / future fix
	produced.	rules.	for the harness EOA.
6	**Mainnet proof not run.**	Mainnet refused in code unless `GUARDIAN_ALLOW_MAINNET=true`.	Held until the owner approves real-value testing.
7	**LLM outage or invalid output.**	Fallback model, then the deterministic rule (Tier 1, LOW risk only); 3rd consecutive failure pauses autonomy. Neither path can widen authority.	—
8	**Key custody.** The session key is decrypted in the worker process.	Encrypted at rest; the master key never reaches the server.	KMS/HSM signer.
9	**Audit-log integrity.** Database records are not tamper-proof.	Chain evidence (UserOperation and transaction hashes) is the authority.	—
10	**Longer exposure window.** 7-day session, 6 ops per 24 h.	Bound fixed on-chain and revocable at any time.	Shorter sessions for cautious owners.
11	**Window count shown from the database.**	The chain enforces the real count; a mismatch can only cause a bundler rejection (fail closed).	—
12	**Judge Sandbox (testnet only).** Anyone with the link can drive the demo account.	Disabled off testnet; sandbox sessions are refused for limits, monitoring, authorize/revoke, approvals, signatures and asset changes; simulated moves are capped at $30 and funded by the demo wallet. Cooldown lifting is testnet-only.	—

Claim

A compromised AI doesn't automatically mean a compromised account. Guardian doesn't claim the system can't lose money. What it does claim is that losses are bounded by an authority the agent can't expand, and that only the master can grant or revoke.